

Untrusted input boundaries

Project: Grounded Learning Service

1. Prepare the purpose, prerequisites and materials

Teach the learning cycle

Primary target: Explain the mechanism and terminology of untrusted input boundaries

Session · Sequence and minutes · Resources

Session: Session 1 · Understand · 45 min

Sequence and minutes: 0–7: recall and prerequisite; 7–15: inspect the concrete case and predict; 15–30: teacher models the worked trace; 30–40: learners explain a step using the text and visual; 40–45: check the core idea.

Resources: Sections 1–6; record the brief recall in the workbook.

Session: Session 2 · Practise · 45 min

Sequence and minutes: 0–5: retrieve the procedure; 5–15: W2 completion practice; 15–23: explain and check with a partner; 23–30: each learner answers the misconception check; 30–40: targeted reteaching or a harder variation; 40–45: prepare the investigation.

Resources: Sections 7–10; use the matching workbook W2 and misconception check.

Session: Session 3 · Investigate and transfer · 45 min

Sequence and minutes: 0–5: retrieve the decision rule; 5–20: investigate or trace; 20–30: start the independent case; 30–38: connect the project; 38–43: act on feedback; 43–45: plan the return check.

Resources: Sections 9 and 11–14. Give extra time to finish the full task set; use Section 15 when the week includes a coding lab.

This is a starting allocation of 135 minutes, not a validated duration. Preserve all named topics. Schedule extra time for connected examples, the full investigation, independent cases and project building. Repeated copies of a case share one recorded attempt; they are not new evidence.

Case exposure check: this source example appears in ai-3/31, ai-6/18. Reuse a familiar case for recall or

modelling; verify that the case used to assess transfer has not already received feedback.

Retrieval answer guidance

External side effects and recovery

Without opening the old lesson, explain one key idea from External side effects and recovery. Give an example and a mistake that the idea helps you avoid.

Look for: Explain the mechanism and terminology of external side effects and recovery

Reference example, not the only acceptable wording: Teacher explanation: External effects can succeed while their acknowledgement is lost. Recovery must inspect committed state before repeating the operation. The mock ledger records prepared, committed or unknown per operation ID. Retry a committed operation by returning its result; reconcile unknown status instead of assuming failure. Preserve compensation as a separate authorised action.

Approval gates and idempotency

Without opening the old lesson, explain one key idea from Approval gates and idempotency. Give an example and a mistake that the idea helps you avoid.

Look for: Explain the mechanism and terminology of approval gates and idempotency

Reference example, not the only acceptable wording: Teacher explanation: Approval gates bind side effects to an actor, exact version and destination. Idempotency prevents repeated requests with the same key from repeating a committed effect. The mock submission requires approval for request version v1 and destination D. Store key -> committed result. Reusing the same key with the same payload returns that result; the same key with different payload is rejected.

Logs traces and privacy

Without opening the old lesson, explain one key idea from Logs traces and privacy. Give an example and a mistake that the idea helps you avoid.

Look for: Explain the mechanism and terminology of logs traces and privacy

Reference example, not the only acceptable wording: Teacher explanation: Logs support diagnosis, but excessive recording can expose private content. Trace IDs link stages without storing complete sensitive inputs. For this policy log trace ID, stage, status, duration and error category; do not log passcodes, student text or teacher answers. Restrict access and declare retention.

Two 45-minute sessions. Untrusted input must be treated according to a contract before reaching code, queries or tools. Data that resembles instructions does not acquire execution authority. Use the supplied constructed scenarios to make the mechanism inspectable. Collect W4 before sharing solutions. Students should name intermediate evidence and limitations; classroom pacing and learning effectiveness remain unvalidated.

Outcomes

Explain the mechanism and terminology of untrusted input boundaries

Apply the stated procedure to a new case with a traceable result

Identify an assumption or limitation and design a revealing follow-up

Preparation

Lesson and workbook; paper and pencil

Calculator and optional local Python 3 for arithmetic; no live API or private data

Prepare the fresh retry separately and withhold its solution until after collection

Prerequisite answer

A result depends on the inputs, procedure and conditions that produced it. Preserve data roles and distinguish observed outcomes from predictions or unmeasured conditions. If the prior concept cannot be explained, use a short retrieval activity before this chapter.

End goal for the pictorial case

Explain untrusted input boundaries using the deciding step in this fictional service.

This added worked case illustrates the week's main idea. Retain all original and connected topics; schedule its practice within the teaching cycle.

2. Explain and model the mechanism

Untrusted input must be treated according to a contract before reaching code, queries or tools. Data that resembles instructions does not acquire execution authority.

Begin by writing the question the procedure is intended to answer. Identify the information already supplied, the information it will produce and the information still missing. These are constructed classroom examples; they do not require live accounts, private records or an external service. Do not treat a plausible explanation as a measured outcome.

For the toy lookup accept room IDs matching one uppercase letter plus one digit. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters.

Before applying the procedure, write its units, denominator or decision boundary where relevant. A partner should be able to repeat each step using the same inputs. If a required input is absent or violates the stated contract, record that condition explicitly instead of quietly replacing it with a convenient value.

Term · Meaning

Term: Untrusted input

Meaning: Data whose claims or control intent have not been authorised

Term: Full match

Meaning: Validation covering the whole input

Term: Injection boundary

Meaning: A separation preventing data from becoming executable control

Untrusted input boundaries — evidence trace

Input and scope · Check or calculation · Conclusion and limit

Input and scope: Inputs A1 and delete_all() are supplied to room lookup.

Check or calculation: For the toy lookup accept room IDs matching one uppercase letter plus one digit. Perform exact dictionary lookup; never evaluate user strings as code. Reject invalid length or characters.

Conclusion and limit: A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Guided: A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string. Qualification: A format check does not grant resource access; authorisation follows separately. Exit: accept a concrete variation with its predicted outcome and a stated condition that would challenge the mechanism; reject a claim resting on unmeasured evidence.

Model the reasoning aloud

Use the complete worked example below before asking learners to complete W2. Reveal a small part, invite a prediction, then explain the deciding step. These teacher notes contain solutions; do not reveal the independent case answer during modelling.

Inputs A1 and delete_all() are supplied to room lookup.

A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

Compare the intermediate evidence with the final statement. Explain why each number or decision follows from the stated inputs. The conclusion belongs to this scenario and procedure; changing the inputs, evaluation population or authority can change what it establishes. Retain the raw record so a later revision can be compared honestly.

Optional local lab: predict the printed result before running this standalone Python 3 example. Change one relevant boundary input, record the outcome and state the contract or statistical assumptions. The program uses fictional values and the Python standard library; it performs no external operations.

```
import re

def validate_identifier(value):
    return type(value) is str and re.fullmatch('[A-Z][0-9]', value) is not
    None

print(validate_identifier("B2"))
```

Thinking move · Teacher prompt

Thinking move: Plan

Teacher prompt: What is given? What is the question? Which procedure fits these facts?

Thinking move: Do

Teacher prompt: Point to each input and intermediate step in the worked trace. Name the rule that allows the next step.

Thinking move: Check

Teacher prompt: Does the output answer the question? Which assumption or limitation prevents a larger claim?

Use the diagram and verbal explanation together. Ask learners to match a sentence to a specific visual step; do not assign learners fixed visual or auditory learning styles.

A pictorial worked case: Untrusted input boundaries

Check shape before permission. A toy tool accepts exactly one ASCII lowercase letter followed by one digit, with no trimming.

The facts we will use

Inputs h3, H3, h30 and "h3 ". Shape acceptance never grants access by itself.

Untrusted input boundaries

Start with the supplied facts

Follow each arrow. Ask which fact allows the next step.



1. Validate h3

Two characters with the required case and digit pass.



2. Reject wrong shapes

H3 has wrong case; h30 and the trailing-space input have wrong length.



3. Check authority next

An accepted identifier still needs trusted authorisation.

CHANGE ONE THING

Replace h3 with z0.

Explain the changed result using the matching lesson.

Read the picture one step at a time

Step · What happens and why

Step: 1. Validate h3

What happens and why: Two characters with the required case and digit pass.

Step: 2. Reject wrong shapes

What happens and why: H3 has wrong case; h30 and the trailing-space input have wrong length.

Step: 3. Check authority next

What happens and why: An accepted identifier still needs trusted authorisation.

Match each pictured step to the supplied facts. This is a worked teaching case, not an independent assessment.

Why this result follows

Input shape and permission answer different questions. Silently normalising these inputs would change the stated contract.

What this example does not establish

Some systems normalise inputs explicitly; this fictional contract deliberately does not.

Change one thing in the pictured case

Change: Replace h3 with z0.

Prediction: The shape passes; resource access is still undecided.

Reason: Structure contains no evidence of ownership or user permission.

Ask while showing the picture

Cover the result. Ask learners to name the inputs and predict the next step. Uncover one step, connect the icon to the actual procedure, and explain its evidence. Then change the supplied condition and compare. The picture is a representation; it does not document execution of a real AI model.

3. Demonstrate and guide practice

Time or stage · Teacher action

Time or stage: Session 1: 0–7 minutes

Teacher action: Retrieve the prerequisite; identify the input, procedure and evidence source.

Time or stage: 7–18 minutes

Teacher action: Explain section 1 and vocabulary. Complete W1 with a mechanism-based explanation.

Time or stage: 18–32 minutes

Teacher action: Trace the declared procedure and worked case. Complete W2, recording intermediate steps.

Time or stage: 32–45 minutes

Teacher action: Discuss the diagram with the worked input; use W3 to distinguish measured claims and limitations.

Time or stage: Session 2: 0–8 minutes

Teacher action: Retrieve the worked reasoning and collect the guided response before discussing it.

Time or stage: 8–20 minutes

Teacher action: Compare a proposed boundary variant with the original case; identify what remains fixed.

Time or stage: 20–35 minutes

Teacher action: Collect W4 independently. Require the procedure trace and the bounded conclusion.

Time or stage: 35–45 minutes

Teacher action: Use W5 and exit responses for feedback. Administer the fresh retry after feedback and preserve both attempts.

Use the worked example in Sections 3 and 6. Collect a prediction before revealing its result; ask the learner to point to each intermediate fact.

Provide an input/procedure/result/limit frame and a calculator when needed. Ask students to identify the first step before completing the whole trace. Extension: compare two concrete variants of this mechanism while holding unrelated conditions fixed; report both successful and unsuccessful outcomes.

Reduce help deliberately

Completion task: Inputs A1 and delete_all() are supplied to room lookup. Show the intermediate steps and give the conclusion with its scope.

Teacher check: Teacher explanation: A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

Start by identifying the given inputs together. Leave the intermediate steps blank. If needed, model one step, then withdraw that help on the next step. Move to a full trace only when the partial trace is understood. For partners, alternate explainer and checker; collect a response from every learner before discussion.

Individual reasoning check

Use the worked case for Untrusted input boundaries. Proposed explanation: “The worked result establishes every future case”. Decide whether this explanation is supported. Point to the step or supplied fact that decides; explain your repair if needed.

Expected correction: A format check does not grant resource access; authorisation follows separately.

Collect explanations, not only yes/no votes. If a misunderstanding is common, re-model the relevant step for the class. If it affects a few learners, give a short targeted group explanation while others solve a more demanding variation.

Pictorial practice question

Classify h3, H3, h30 and the trailing-space input by the stated shape contract. Does a valid z0 grant record access, and which separate gate still remains?

Reasoned teacher answer

Two characters with the required case and digit pass. H3 has wrong case; h30 and the trailing-space input have wrong length. An accepted identifier still needs trusted authorisation. Changed case: The shape passes; resource access is still undecided. Structure contains no evidence of ownership or user permission.

Changed-case reasoning: The shape passes; resource access is still undecided. Structure contains no evidence of ownership or user permission.

Collect each learner’s explanation before discussion. Use the first missing connection between input, deciding step and result to choose support. This question is worked-case practice, not fresh mastery evidence.

4. Run the investigation and diagnose misconceptions

The worked result establishes every future case: A format check does not grant resource access; authorisation follows separately.

A missing input may be replaced without recording the change: A replacement changes the evidence or contract. Record the change and its justification; do not silently turn unknown into a measured value.

Repeating an assessed case is new independent evidence: A replay checks consistency. An example used for feedback or revision cannot later be described as untouched final evaluation.

Use Section 9 for the evidence ledger. Add a boundary or missing-input case and record the expected response before checking. More successful repeats of one case do not establish wider coverage.

Match the support to the first error

What the response shows · Next teaching action

What the response shows: Missing or misread facts

Next teaching action: Read the case aloud, mark supplied versus unknown facts, and let the learner restate it.

What the response shows: Wrong procedure

Next teaching action: Return to the deciding step in the worked case. Contrast it with the proposed incorrect explanation.

What the response shows: Arithmetic or implementation error

Next teaching action: Trace intermediate values or lines; preserve the first mismatch and retry that step.

What the response shows: Correct result without a reason

Next teaching action: Ask for a trace and a changed case before marking independent understanding.

What the response shows: An unsupported wider claim

Next teaching action: Ask which supplied evidence supports the claim and which further observation would be needed.

Offer an oral explanation, drawing, enlarged visual or fewer examples when that removes a reading/writing barrier. Keep the same reasoning goal. Stretch secure learners by changing a boundary or assumption and asking them to defend the effect, not simply by assigning more of the same questions.

5. Assess and explain the answers

Guided and exit questions

Guided: A1 passes the format; `delete_all()` fails. Neither is executed as code, including any instruction-shaped string. Qualification: A format check does not grant resource access; authorisation follows separately. Exit: accept a concrete variation with its predicted outcome and a stated condition that would challenge the mechanism; reject a claim resting on unmeasured evidence.

W1 Explain the mechanism

Explain the weekly mechanism in your own words. Use the worked scenario to name its input, decision rule and output.

Teacher explanation: Untrusted input must be treated according to a contract before reaching code, queries or tools. Data that resembles instructions does not acquire execution authority. For the toy lookup accept room IDs matching one uppercase letter plus one digit. Perform exact dictionary lookup; never

evaluate user strings as code. Reject invalid length or characters.

W2 Trace the worked case

Inputs A1 and delete_all() are supplied to room lookup. Show the intermediate steps and give the conclusion with its scope.

Teacher explanation: A1 passes the format; delete_all() fails. Neither is executed as code, including any instruction-shaped string.

W3 Audit the limit

A report omits this qualification: A format check does not grant resource access; authorisation follows separately. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

Teacher explanation: A format check does not grant resource access; authorisation follows separately. State the observed result separately from the unverified or out-of-scope claim; preserve the original evidence rather than inventing a missing fact.

W4 Apply a new case independently

Classify B2, b2, B22 and B2; DROP under the exact format.

Teacher explanation: B2 valid; lowercase, extra digit and injected command text invalid. Validation and safe lookup both apply.

W5 Design a revealing follow-up

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison. Do not reuse W4 as a new final test after receiving feedback.

Teacher explanation: Accept a concrete variant of the worked input or a missing/conflicting/boundary condition, with an expectation derived from the declared procedure. Require preserved settings, original outputs and data roles. A format check does not grant resource access; authorisation follows separately. The new case should test this particular mechanism rather than merely restate the original result.

Independent assessment and fresh retry

W4: B2 valid; lowercase, extra digit and injected command text invalid. Validation and safe lookup both apply. Require intermediate reasoning and the stated scope. Fresh retry: Inputs Z9 and Z9 followed by a newline. Expected reasoning: Z9 valid; extra newline fails exact full-match policy. Do not silently trim unless specified. If students need support, record it and reassess with another new case rather than awarding independence to a copied answer.

Assess independent transfer

Selected case: Input format is exactly one ASCII uppercase letter followed by one digit, with no trimming.

Evaluate C0, c0, C00, "C0 ", and None. Does a valid format grant access?

Selected case answer

Only C0 has the required format. Lowercase, extra characters, trailing space and a non-string value fail. Format validation and authorization are separate; matching shape grants no permission.

Dimension · Evidence required

Dimension: Explanation

Evidence required: Names the applicable idea or procedure and ties it to the supplied facts.

Dimension: Trace and result

Evidence required: Preserves the given inputs and shows the relevant intermediate steps; distinguishes a prediction from an observed execution.

Dimension: Limits

Evidence required: States the assumptions, missing evidence or conditions under which the result would change.

Record each dimension as not yet, with support, or independent. Accept a valid alternative procedure with a defensible trace. Do not penalise an honestly recorded model failure if the learner correctly explains its evidence and limits.

Feedback that the learner uses

Name the earliest unsupported step and give one action to repair it. Have the learner make that repair now and explain why. Then assess the relevant skill on a fresh, fully specified case. Confirm it was not previously practised with feedback; solve and check the new case before assigning it. A follow-up design prompt is a starting brief, not automatically an equivalent test.

6. Connect the project, support and next lesson

Add a labelled untrusted input boundaries evidence sheet to Grounded Learning Service. Show how you can explain the mechanism and terminology of untrusted input boundaries. Use the supplied fictional case and keep its inputs, intermediate steps, calculation or prediction, and limitation. Connect this record to last week's record; a matching answer without a trace is insufficient.

Provide an input/procedure/result/limit frame and a calculator when needed. Ask students to identify the first step before completing the whole trace. Extension: compare two concrete variants of this mechanism while holding unrelated conditions fixed; report both successful and unsuccessful outcomes.

Next connection: Sandboxing and resource limits. Preserve the current case record and retrieve its evidence boundary before moving on.

Retain the project ledger and assess a changed case after support. Check the relevant prerequisite before carrying this component forward.

Plan the delayed return

Suggested return points in this level: ai-6/19, ai-6/21, ai-6/24. Use actual classroom dates, adjusting for holidays and gaps. One, three and six teaching weeks are scheduling choices, not a claimed optimal spacing.

At a delayed check, ask for the idea from memory and a changed application. Compare with the earlier independent response and record support used. For a new level, revisit the previous capstone before checking the new prerequisites.

Record · Teacher evidence

Record: Learner code and date

Teacher evidence: _____

Record: Concept and case used; prior exposure

Teacher evidence: _____

Record: Explanation / trace / limits

Teacher evidence: _____

Record: Support and first repair

Teacher evidence: _____

Record: Changed case and delayed outcome

Teacher evidence: _____

Record: Next teaching action

Teacher evidence: _____

Use the evidence to choose reteaching or the next step. A completed page, confidence rating or attractive

project does not by itself demonstrate understanding.

Project evidence from this case

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or evidence that makes the deciding step valid, so another team can review it.